

Hacker



Startup Founder

Zayne Zhang
2025

Do things that don't scale.

01 *whoami*

02 *Learning Cyber*

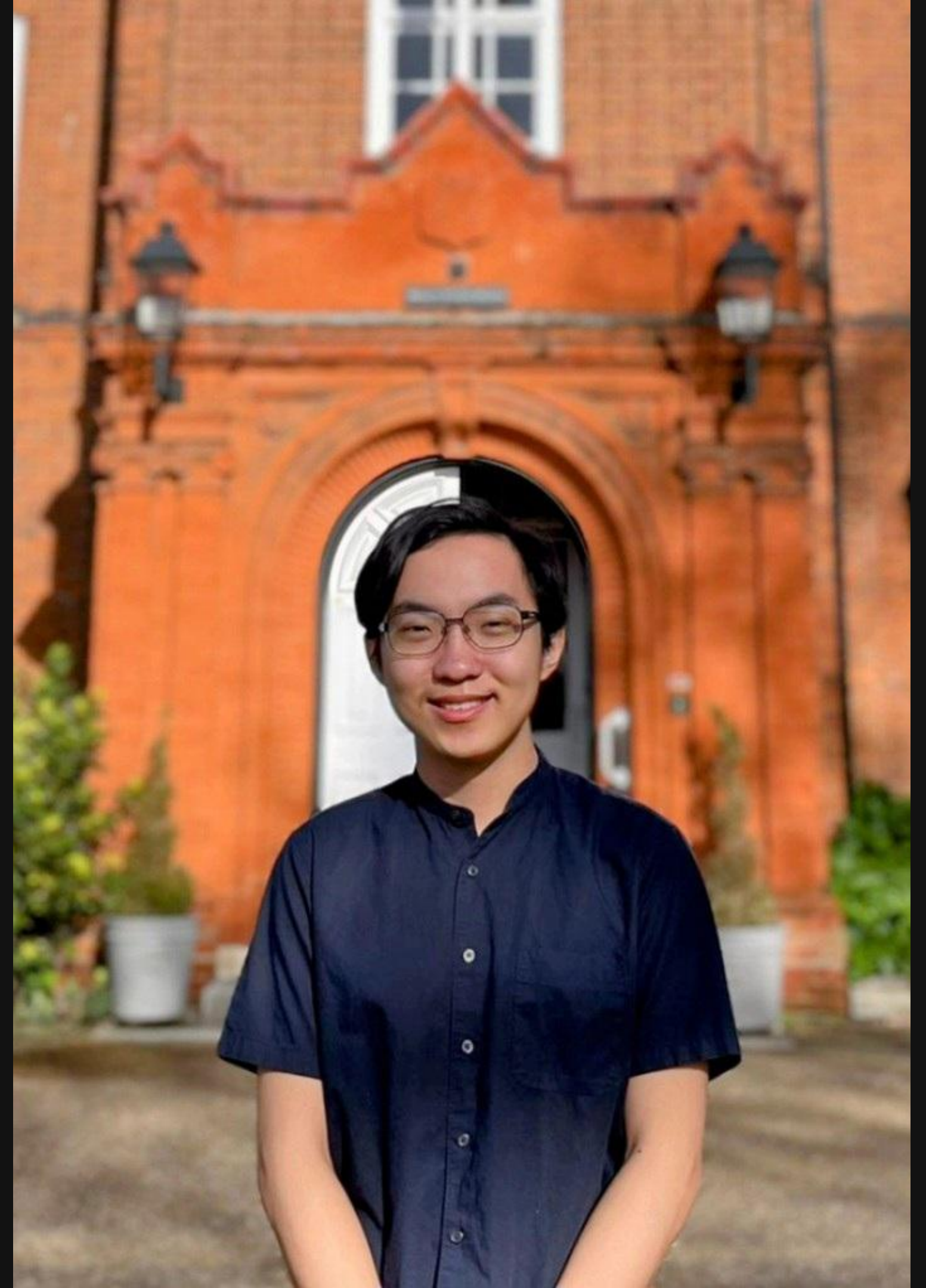
03 *Doing Cyber*

04 *AI in Cyber*

whoami

Zayne Zhang

- CTFs with **Blue Water** (2nd place @ DEF CON CTF in 2023 and 2024)
- Freelance pentester @ **Cure53**
- Spoke at BSides Singapore, London, and Wales
- Co-Founder @ **Hacktron AI**



Learning Cyber

CTF Events

All		Now running	Upcoming	Archive	Format ▾	Location ▾	Restrictions ▾
Name	Date						
GPN CTF 2025	20 June, 10:00 UTC — 21 June 2025						
IERAE CTF 2025 - GMO Cybersecurity Contest	21 June, 06:00 UTC — 22 June 2025						
MaltaCTF 2025 Quals	21 June, 07:00 UTC — 22 June 2025						
cornCTF 2025	21 June, 12:00 UTC — 22 June 2025						
Hack The System - Bug Bounty CTF	27 June, 13:00 UTC — 29 June 2025						
Google Capture The Flag 2025	27 June, 18:00 UTC — 29 June 2025						
Involuntary CTF 2025	27 June, 18:00 UTC — 29 June 2025						
BSides Mumbai CTF 2025	28 June, 10:00 UTC — 29 June 2025						
Junior.Crypt.2025 CTF	01 July, 08:00 UTC — 03 July 2025, 0						
CubeCTF	04 July, 22:16 UTC — 07 July 2025, 0						
R3CTF 2025	05 July, 02:00 UTC — 07 July 2025, 0						
No Hack No CTF 2025	05 July, 08:00 UTC — 07 July 2025, 0						
Cyber Arena	05 July, 10:04 UTC — 06 July 2025, 1						

Do CTFs.

- ctftime.org
- Beware of slop. Generally, the higher the “weight”, the better the CTF.

Learn From Writeups.

- Join the Discord channels for the CTFs.
- Read community writeups.
- Ask for solutions if no one is talking about them.

Repeat.

- You will most likely not solve many challenges in your first CTF.
- And that’s okay! All of the best CTF players I know didn’t either.

Do things that don't scale

Do the hard challenges

We've all seen a CTF like this before...

- "Web": Run `gobuster` and `sqlmap`, rinse and repeat
- "Crypto": Run it through 6 different filters on CyberChef
- "Forensics": Open `.mp3` file on Sonic Visualizer, decode morse code

These are "*feel-good*" challenges that don't help with learning. Do them once, but don't fall into the trap of repeating them over and over again.



Do things that don't scale
Find people who challenge you

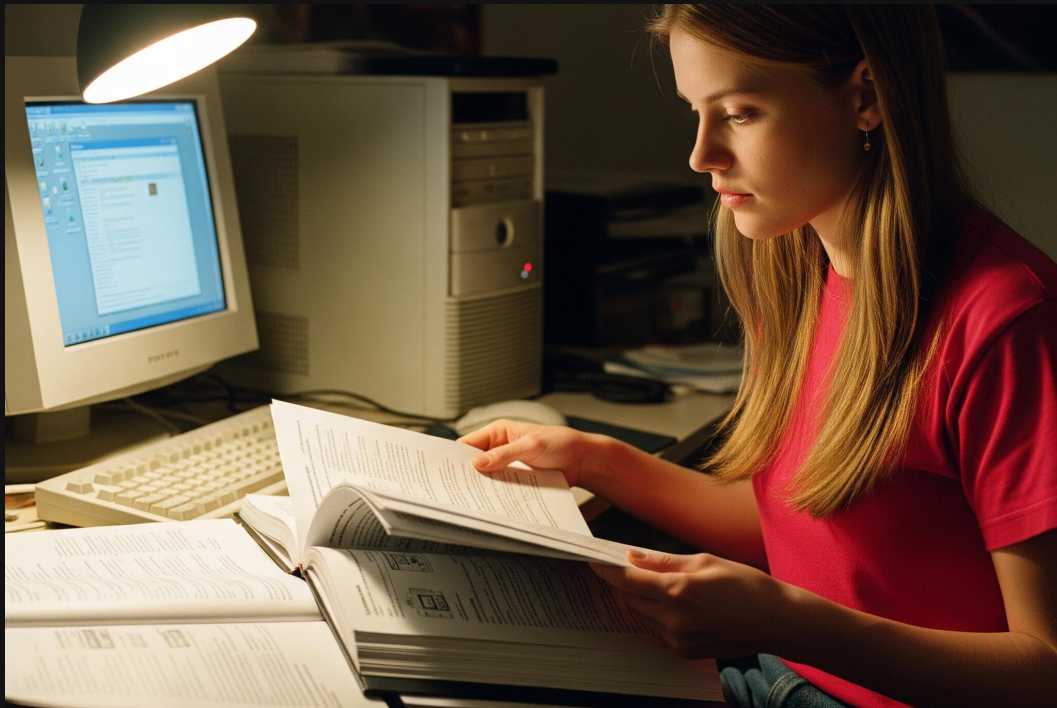
Doing Cyber

“

CTFs are not realistic.
Go do real-world security.

— many people, probably

CTFs would have trained you to...



*Read The F***ing Manual*

- Adapt to new technologies by reading the documentation.
- Speed of searching for and absorbing new information is crucial.



Be Creative

- Ethical hacking is an inherently creative activity.
- You would have learnt to think outside of the box.



Think Like A Hacker

- You would have acquired an adversarial mindset.
- This mindset is universally applicable to any new domain in cybersecurity.

HTTP request smuggling bug patched in mitmproxy

Ben Dickson 25 March 2022 at 11:58 UTC
Updated: 28 March 2022 at 09:17 UTC

Open Source Software Vulnerabilities Hacking Techniques

Bug exploited inconsistencies between intermediary and backend servers



Mitmproxy, an [open source](#), interactive HTTPS proxy service, has patched allowed attackers to stage [HTTP request smuggling](#) attacks against backends. HTTP request smuggling attacks exploit the inconsistencies between the proxy process requests to bypass security controls, gain unauthorized access to application users.

An elusive bug

Zhang Zeyu, the security researcher who reported the bug, discovered the request/response through mitmproxy as part of another request/response.

"While the more obvious attack vectors (e.g., double Content-Length headers, using Content-Length over Transfer-Encoding) are rare nowadays, more subtle deviations from the standard leave certain setups equally vulnerable to request smuggling," he told *The Daily Swig*.



Now go find real bugs.

- The great thing about cybersecurity is that it affects every software you use.
- Start poking around! Bug bounties ([hackerone.com](#)), or just do your own vulnerability research on open-source software.

A photograph of Zayne Zhang, a security researcher, speaking at a podium during a presentation. He is wearing a dark shirt and glasses.

The XS-Leak

```
> let url = "http://secrets.wtl.pw/search?query=asdf#"  
let w = window.open(url + "A".repeat(2 * 1024 * 1024 - url.length - 1))  
< undefined  
> w.origin  
✖ Uncaught DOMException: Blocked a frame with origin "https://www.example.com" from accessing a cross-origin frame.  
at <anonymous>:1:3  
>  
  
> let url = "http://secrets.wtl.pw/search?query=test#"  
let w = window.open(url + "A".repeat(2 * 1024 * 1024 - url.length - 1))  
< undefined  
> w.origin  
< 'https://www.example.com'  
>
```

Failure (< 2MB)

Success (> 2MB)

20/33 — Zayne Zhang @ BSides London 2023

XS-Leaks: Client-Side Attacks In A Post-XSS World - Zeyu (Zayne) Zhang

63%

*bug bounties spent on top
10 common vulnerabilities*

XSS, AuthZ, SQLi, etc. – these
seem quite easy to detect
automatically...

\$1-2K

*typical person-day rate for
a penetration test*

Most bugs found through pentests
aren't that deep...

\$16.6B

*lost to phishing/spoofing in
2024*

Maybe most "hacks" aren't that
interesting after all?

Start doing things that scale...?

It's not just vuln research

The world needs software engineers with security knowledge to build continuous testing into the software development lifecycle, secure-by-default frameworks, and make it harder for users to make mistakes.

AI in Cyber

Software 3.0 (LLMs)

Software 1.0

```
python
def simple_sentiment(review: str) -> str:
    """Return 'positive' or 'negative' based on a tiny keyword lexicon."""
    positive = {
        "good", "great", "excellent", "amazing", "wonderful", "fantastic",
        "awesome", "loved", "love", "like", "enjoyed", "superb", "delightful"
    }
    negative = {
        "bad", "terrible", "awful", "poor", "boring", "hate", "hated",
        "dislike", "worst", "dull", "disappointing", "mediocre"
    }

    score = 0
    for word in review.lower().split():
        w = word.strip(",.!?;:") # crude token clean-up
        if w in positive:
            score += 1
        elif w in negative:
            score -= 1

    return "positive" if score >= 0 else "negative"
```

Software 2.0

10,000 positive examples
10,000 negative examples
encoding (e.g. bag of words)

train binary classifier

parameters

Software 3.0

You are a sentiment classifier. For every review that appears between the tags

<REVIEW> ... </REVIEW>, respond with **exactly one word**, either POSITIVE or NEGATIVE (all-caps, no punctuation, no extra text).

Example 1

<REVIEW>I absolutely loved this film—the characters were engaging and the ending was perfect.</REVIEW>

POSITIVE

Example 2

<REVIEW>The plot was incoherent and the acting felt forced; I regret watching it.</REVIEW>

NEGATIVE

Example 3

<REVIEW>An energetic soundtrack and solid visuals almost save it, but the story drags and the jokes fall flat.</REVIEW>

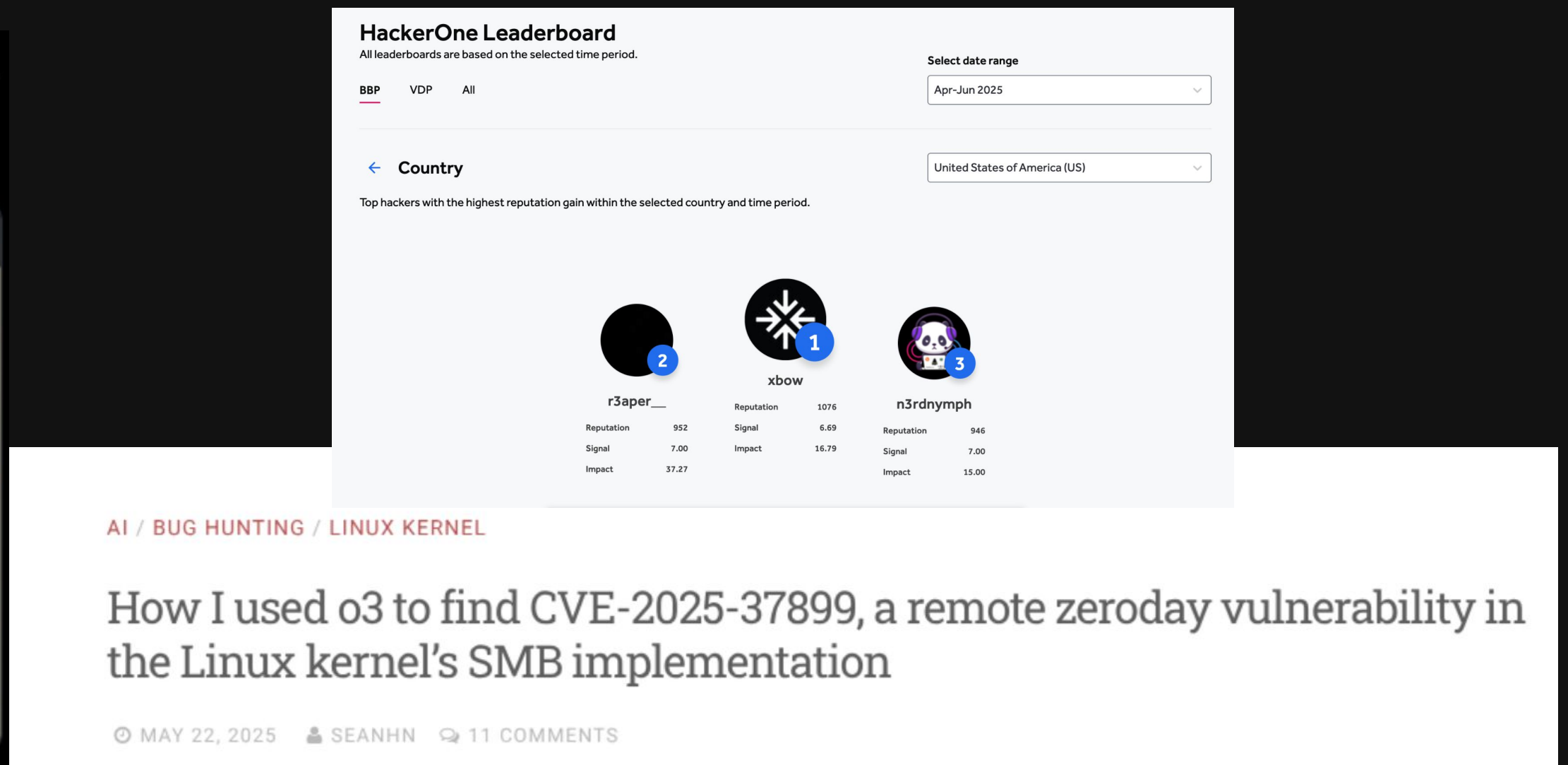
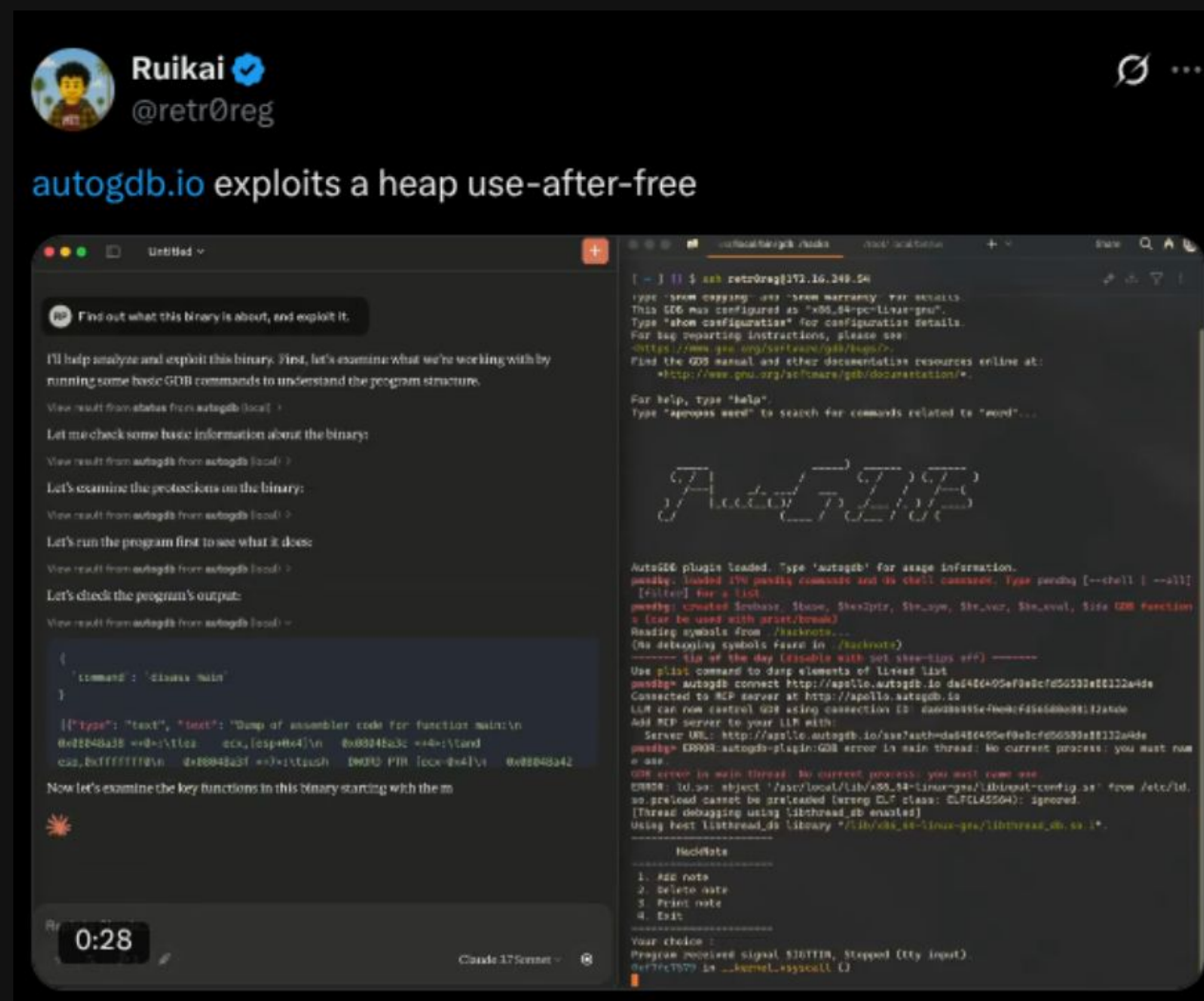
NEGATIVE

Now classify the next review.

Andrej Karpathy: Software Is Changing (Again)

Software 3.0 (LLMs)

- Software 3.0 will replace some features previously written by Software 1.0 and Software 2.0.
- Our industry was a little behind on Software 2.0, but have been quite quick in adopting Software 3.0. We're seeing early signs of partially/fully autonomous security engineers.



Scaling Laws

- Length of tasks AI can complete is doubling every 7 months
- Model size, data, and compute will continue to increase, driving improvements in AI

What's left to solve?

- Deeper knowledge
- Memory & context window management
- Multimodal integration
- Coordinating larger tasks

What AI means for security

- Just like programmers currently do for coding, penetration testers will start using AI as a core part of their daily workflow.
- For now, human-AI collaboration is important (similar to humans checking AI's work when vibe coding).
- Text is not a good user interface. Penetration testing tools need to figure out what a good UI looks like.
- Challenges may include keeping AI agents in check, especially if they are able to perform potentially destructive actions.

What Hacktron is building

We are building the world's first fully autonomous security researcher.

We believe that:

- The world is headed towards specialised models & agents for specific knowledge silos
- To solve knowledge, you need security researchers to contribute
- To solve large tasks, you need to provide AI agents with the same tools as what human researchers have at their disposal



What Hacktron is building

Mobile Apps rewarded
SQL Injection [redacted]

[redacted] with \$700.



Noob,

Congratulations! [redacted] awarded
\$700 for your submission SQL Injection [redacted]
[redacted]

Fix potential XSS issue in MediaEmbed #310

Merged ershad merged 6 commits into `main` from `comp-assets-xss-tiptap-fix` yesterday

Conversation 3 Commits 6 Checks 69 Files changed 5 +59 -9



ershad commented 2 days ago · edited by coderabbitai bot

Member

Thanks to @HacktronAI for finding the potential XSS issue and sending us the patch.

Summary by CodeRabbit

- New Features**
 - Enhanced security by sanitizing embedded HTML content before display to prevent unsafe HTML injection.
 - Improved embedded media handling by modifying API requests to control embed formats.
- Chores**
 - Added a new dependency to improve HTML sanitization for embedded media.



root and others added 4 commits last month

fix(xss): Sanitize HTML in Tiptap Raw node rendering

634db20

fix: allow iframe, omit script in embed code

d9e0e63

Merge remote-tracking branch 'origin/main' into fix/GUM-01-001-dom-xss

Verified

6fbaff4

Update

Verified

dc7ffe7

ershad self-assigned this 2 days ago



coderabbitai bot commented 2 days ago · edited

Contributor

Walkthrough

Reviewers

coderabbitai[bot]

Assignees

ershad

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

Notifications

Customize

Subscribe

You're not receiving notifications from this thread.

2 participants

Hacktron finds pre-auth RCE in Dassault Delmia Apriso

2025-06-03 by rootxharsh | Hacktron , Research | #Hacktron , #Research



Thank You!

zayne@hacktron.ai

[@zeyu2001](https://twitter.com/zeyu2001)

analogue.computer / hacktron.ai